Institut Supérieur d'Informatique de Mahdia

République Tunisienne
Ministère de l'Enseignement supérieur et de la Recherche scientifique

1

Cours sécurité informatique

Elaboré par : **Ben Hassine Ines**

ines.benhassine@yahoo.fr
ines.zbenhassine@gmail.com
ines.benhassine@isima.u-monastir.tn

Chapitre I

Notions de base
de la sécurité informatique

Pourquoi la sécurité ?

- L'information est une ressource stratégique.

- Insécurité dans les technologies de communications:
  - L'Ethernet est *promiscuous*.
  - TCP/IP envoi des données en clair (les données peuvent être visualisées) et les applications doivent sécuriser les données, etc.
  - L'adresse IP de la source peut être *spoofée*.

Pourquoi la sécurité ? (2)

- Un système d'information représente un patrimoine essentiel de l'entreprise

  ➔ Nécessité de protection du SI (Sécurité du SI).

- Menaces aux systèmes d'informations : erreurs humaines, employés malhonnêtes, accès externe, etc.
- Une intrusion à un SI peut causer des dégâts divers (vol des données confidentielles, pertes financières suite à des transactions erronées, perte de confiance des clients) et peut même menacer son existence sur le marché.

Que couvre la sécurité en général ?

- Prévention
  - Prendre des mesures afin d'empêcher les biens et les actifs d'être attaqués.
- Détection
  - Prendre des mesures afin de détecter quand, comment, par qui un actif ou un bien a été endommagé.
- Réaction
  - Prendre des mesures après un incident de sécurité afin de pouvoir restaurer les biens et les actifs, ou réduire l'impact de l'incident.

Intrus (*Intruder*) : Définition

- L'entité responsable d'une attaque de sécurité, capable de:
  - Accéder à des ressources internes propres à la cible de l'attaque de sécurité (appelée **victime**) de façon non autorisée.
  - Manipuler/agir sur le fonctionnement interne des machines.
  - Deviner/Décrypter les mots de passe utilisés pour protéger l'accès à des comptes utilisateurs ou à des services (type spécifique d'intrus : *cracker*).

Menace : Définition

- Une menace est «un signe qui laisse prévoir un danger»
- La menace peut être une personne, un objet, ou un événement qui peut créer un danger pour un bien (en terme de confidentialité, intégrité ou disponibilité).
- Exemple:
  - Un virus circule sur le réseau local.
  - Un programme installé sur la machine semble être en train d'épuiser les ressources disponibles (mémoire, CPU).

Une attaque de sécurité est la réalisation d'une menace.

Exemples de menaces/attaques

- Accès non autorisé.
- Perte de l'intégrité du système.
- Déni de service.
- Les virus.
- Coupure d'électricité.
- Panne du matériel.
- Divulgation des données confidentielles.
- Vol des données.
- Destruction des données.

Vulnérabilité : définition

- Faille ou bug pouvant être utilisé pour obtenir un niveau d'accès illicite à une ressource d'informations ou des privilèges supérieurs à ceux considérés comme normaux pour cette ressource.
- Une vulnérabilité est exploitée par une menace pour engendrer une attaque.
- Exemples de vulnérabilités :
  - Utilisation des mots de passe non robustes.
  - Présence de comptes non protégés par mot de passe.

Services, mécanismes et attaques.

- Attaques de sécurité: Actions qui entraînent la compromission de la sécurité de l'information possédée par une organisation.

- Mécanismes de sécurité: Mécanismes désignés à détecter ou à empêcher ou à récupérer suite à une attaque de sécurité.

- Services de sécurité: Services améliorant la sécurité du traitement de données et du transfert d'informations. Ces services s'opposent aux attaques de sécurité et font utiliser des mécanismes de sécurité.

Services de sécurité

- Objectif:
  - Empêcher et détecter les attaques de sécurité.
  - Améliorer et renforcer la sécurité.
  - Répliquer les fonctions usuelles utilisées sur les documents physiques:
    - Signature, date.
    - Protection contre la divulgation, la falsification, et la destruction.
    - Certification.
    - Enregistrement.

Services de sécurité (2)

- (X.800, Security architecture for OSI) regroupe les services de sécurité en cinq catégories:
  - Authentification
  - Contrôle d'accès
  - Confidentialité
  - Intégrité
  - Non répudiation

Services de sécurité: Authentification

- S'assurer que l'origine du message soit correctement identifiée:
  - Assurer le receveur que le message émane de la source qui prétend avoir envoyé ce message.
  - Assurer l'authenticité des entités participantes: chacune des entités est celle qui prétende l'être.
  - Empêcher la perturbation de la connexion par une tierce partie qui se fait passer pour une entité légitime (émission ou réception non autorisée).
- Techniques utilisées: Cryptage, signature numérique, secret (mots de passes, PIN).

Services de sécurité: Contrôle d'accès

- Empêcher l'utilisation non autorisée d'une ressource (serveur, application, etc.)
- Le service de contrôle d'accès :
  - Définir qui a le droit d'accéder aux ressources ?
  - Déterminer sous qu'elles conditions ceci peut avoir lieu ?
  - Défini ce qu'une entité est autorisée de faire lors de l'accès à une ressource.

Services de sécurité: Confidentialité

Protection des données transmises contre les attaques passives, et protection des flux de données contre l'analyse.

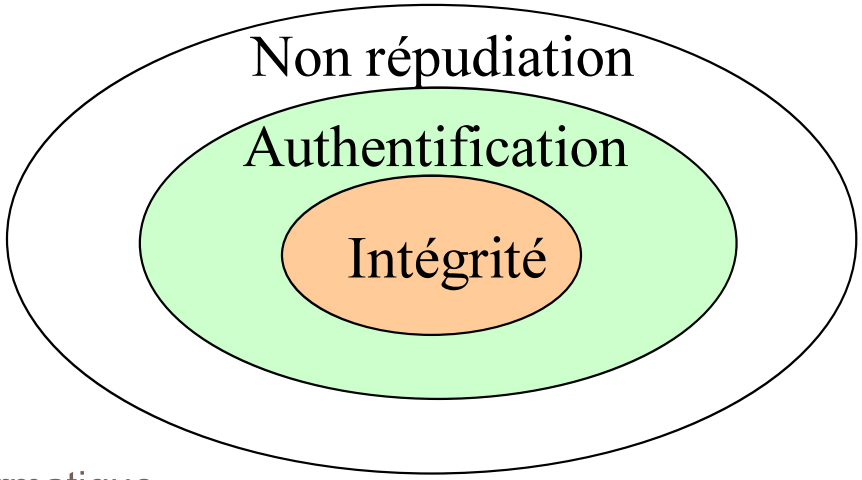
- Préservation du secret des données transmises. Seulement les entités communicantes sont capable d'observer les données.
- Plusieurs niveaux de confidentialité :
  - Protection de tous les données échangées tout au long d'une connexion.
  - Protection des données contenues au niveau d'un seul bloc de donnée.

Services de sécurité: Intégrité

- Détecter si les données ont été modifiées depuis la source vers la destination
  - Service orienté connexion: Protection contre la duplication, la destruction, l'insertion, la modification, le rejeu, le reclassement, etc.
  - Service non orienté connexion: Protection contre la modification uniquement.
- Techniques utilisées: cryptage, signature numérique, contrôle d'accès, contrôle d'intégrité

Services de sécurité: Non répudiation

- Empêche l'émetteur ou le receveur de nier avoir transmis ou reçu un message.
  - Non répudiation d'envoi: Le destinataire prouve que la source prétendue vient démettre le message en question.
  - Non répudiation de réception: L'émetteur prouve que son message a été reçu effectivement par la destination prétendue.
- Techniques utilisées: signature électronique



Les attaques de sécurité

- X.800 et RFC 2828 classifient les attaques selon deux classes :
  - **Attaques passives :** tentent de collecter ou utiliser des informations relatives au système, mais elles n'affectent pas les ressources du système.
  - **Attaques actives :** tentent d'introduire des modifications sur les ressources du système ou affecter leur fonctionnement normal.

Attaques de sécurité: Attaques passives

- Difficiles à détecter puisqu'elles n'entraînent aucune altération de données.
  - **Interception:** l'intrus est capable d'interpréter les données et d'extraire l'information (ex: email contenant des informations confidentielles, communication téléphonique) à partir du trafic échangé.
  - **Analyse de trafic:** même en présence de mécanismes de cryptage des données transmises, l'intrus peut extraire des informations utiles sur la communication en observant l'identité des utilisateurs, la fréquence et la longueur des messages échangés, etc.
- Détection difficile, protection assez simple (ex: cryptage)

Attaques de sécurité: Attaques actives

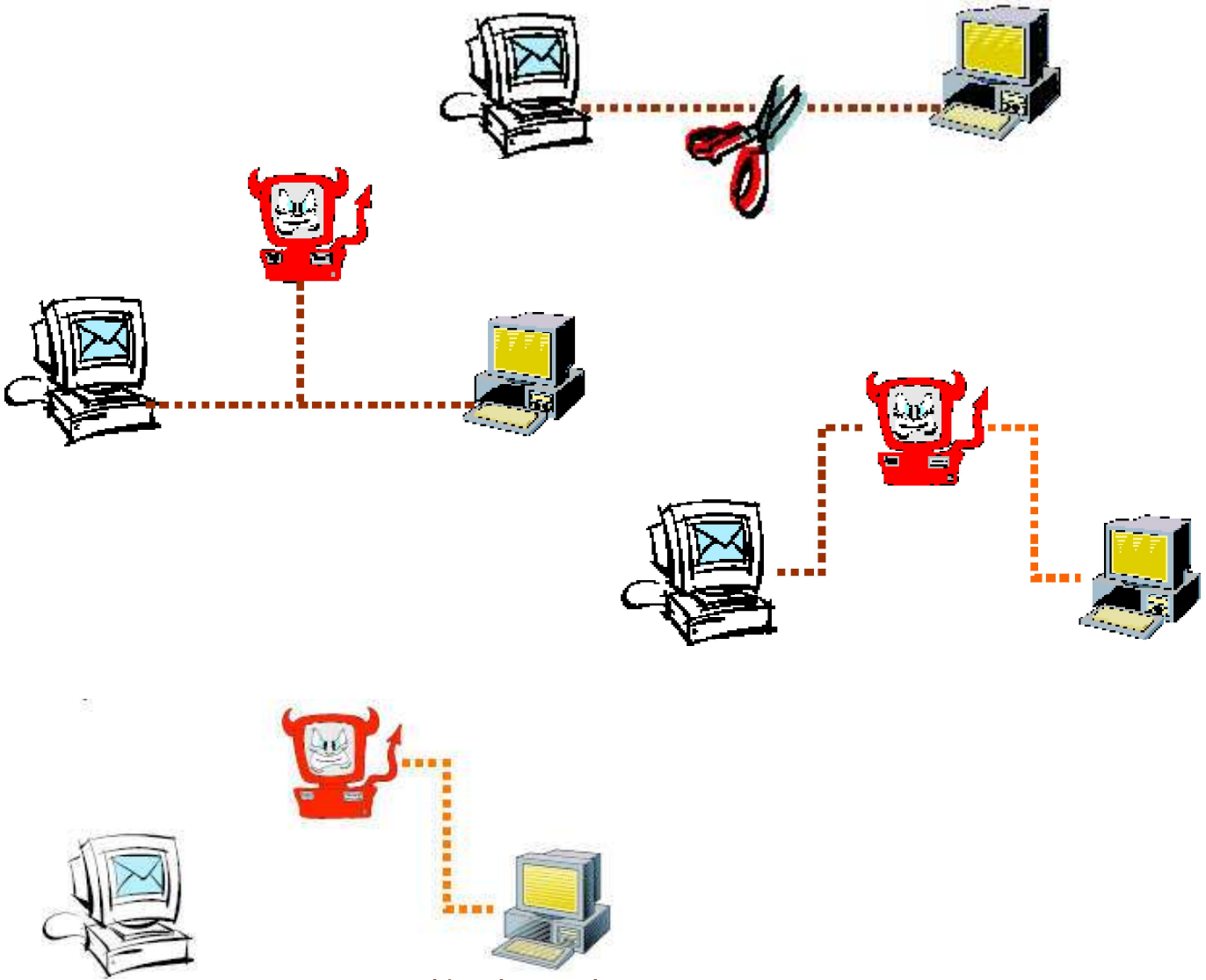
- Mascarade: Une entité prétend être une entité différente afin d'obtenir des privilèges supplémentaires. Généralement ceci fait appel à d'autres techniques d'attaques actives.
- Rejeu (Replay): capture passive des données et leurs transmission ultérieure en vue de réaliser des actions non autorisées.
- Fabrication: Création et injection de messages afin de produire un effet non autorisé.
- Modification: Altération, destruction, ou reclassement d'une partie des messages échangés en vue de produire un effet non autorisé.

Attaques de sécurité: Attaques actives

- Déni de service: Empêcher ou inhiber l'utilisation normale des moyens de communications:
  - Interruption et suppression des messages en direction d'une destination particulière (ex: service d'audit sécurité)
  - Perturbation de l'utilisation normale des ressources (réseau ou système) en les surchargeant de trafic inutile pour dégrader leurs performances.

Termes à ne pas confondre

- Interruption
- Interception
- Modification
- Fabrication



Mécanismes de sécurité

- Cryptage
  - Utilisation d'algorithmes mathématiques pour transformer les messages en une forme inintelligible.
  - La transformation dépend d'un algorithme et de zéro à plusieurs clés.
- Signature numérique
  - Ajout de données, ou transformation cryptographique irréversible, à une unité de données afin de prouver la source et l'intégrité de cette unité de données.
- Échange d'authentification
  - Mécanisme assurant l'identité d'une entité à travers un échange d'information.

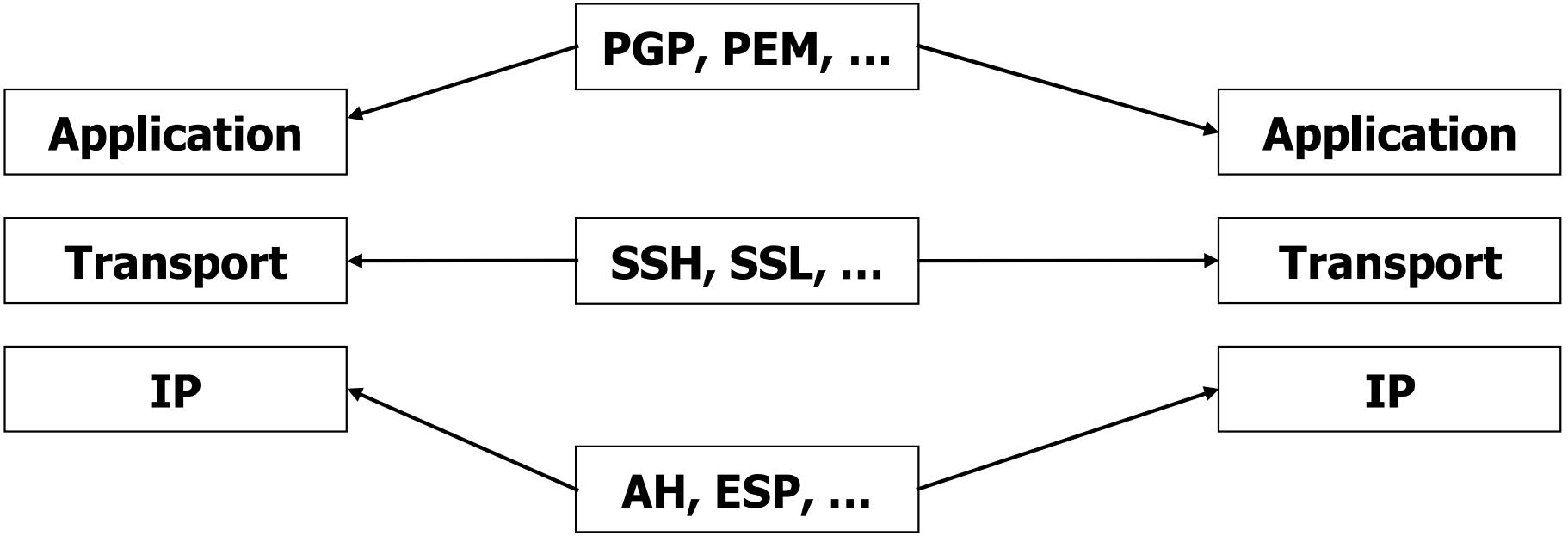
Mécanismes de sécurité (2)

- Notarization:
  - Utilisation d'une tierce partie afin d'assurer certaines propriétés liées à un échange de données.
- Horodatage (Timestamping)
  - Inclusion d'une date et d'un temps correct dans un message.
- Mécanismes non cryptographiques:
  - *Traffic Padding* : Insertion d'un certain nombre de bits au niveau d'un flux de données pour faire échouer les tentatives d'analyse du trafic.
  - Détection d'intrusions
  - Implémentation de Firewalls

Sécurité dans les couches de protocoles

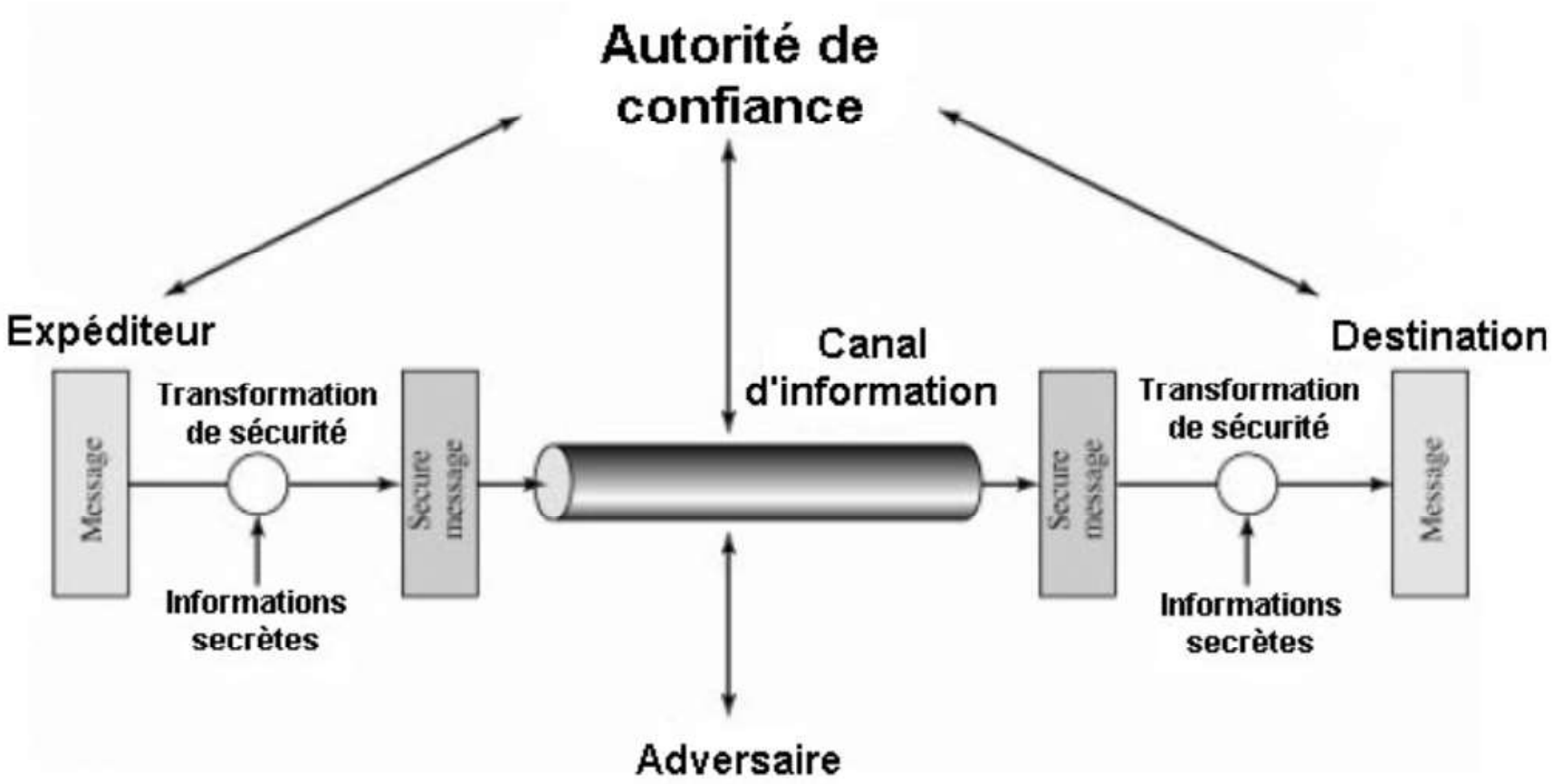
- Besoin de la sécurité dans plus d'une couche (routage, transport, application)
- La sécurité de bout en bout est plus simple à fournir dans les couches supérieures, que la sécurité de point à point dans les couches inférieures.
- Les mécanismes de sécurité dans les couches supérieures sont généralement implémentés sur des logiciels. Les mécanismes de sécurité dans les couches inférieures sont généralement implémentés sur du matériel.

Sécurité dans les couches de protocoles



- PGP: Pretty Good Privacy, PEM: Privacy Enhanced Mail
- SSH: Secure Shell, SSL: Secure Socket Layer
- AH: Authentication Header, ESP: Encapsulating Security Payload.

Modèle de sécurité réseau

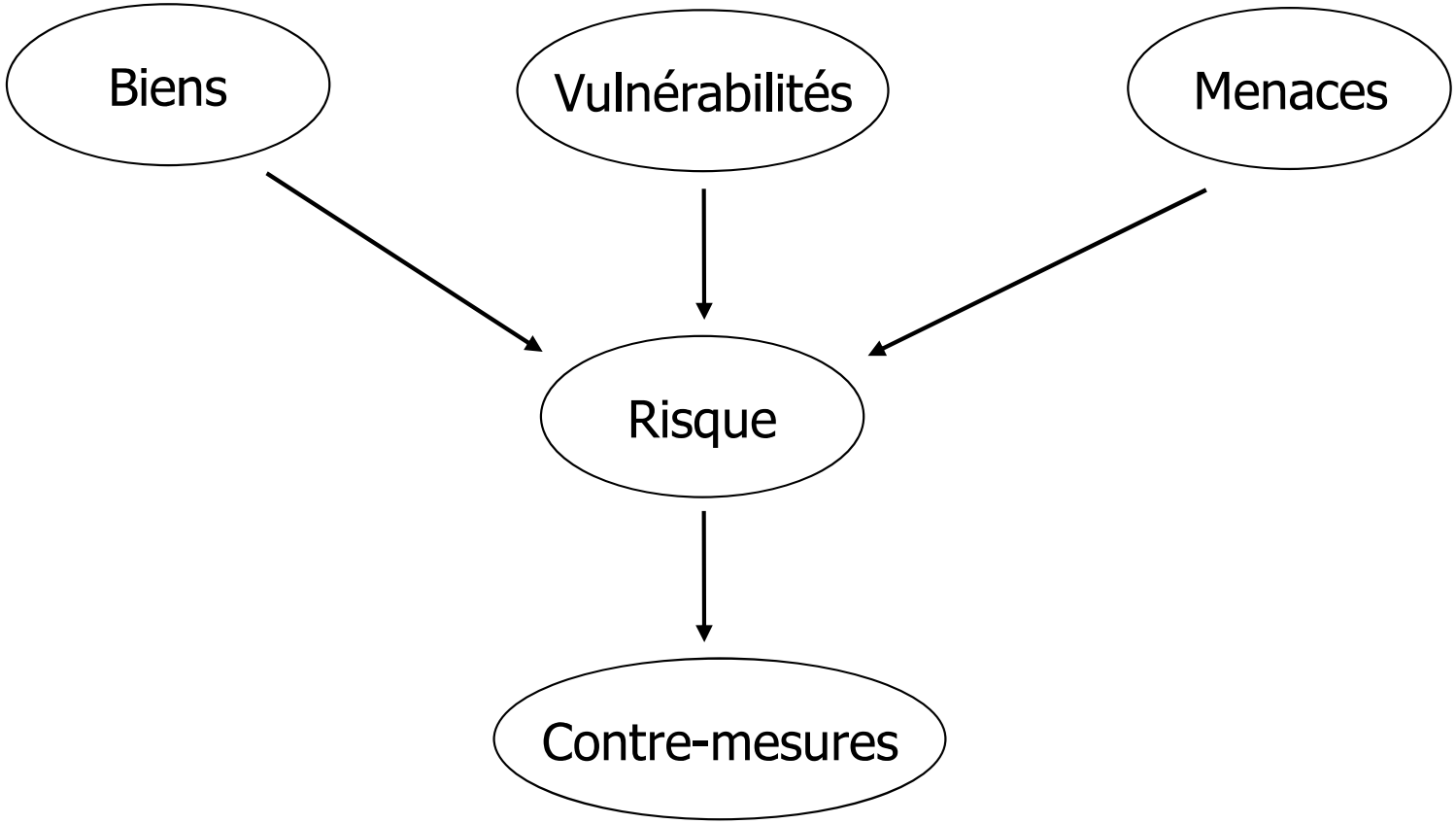


Modèle de sécurité réseau

- Nécessité de
  - Sélectionner une fonction de filtrage appropriée afin d'identifier les utilisateurs et de s'assurer qu'uniquement les personnes autorisées accèdent aux ressources et informations du système.
    - Exemple: Mots de passe, certificats numériques, etc.
  - Implémenter des contrôles internes afin de surveiller l'activité des utilisateurs et analyser les informations pour détecter les actes malveillants.

Gestion de risque

Modèle:



Gestion de risque (2)

- Inventaire et estimation des biens
  - Types de Biens (Asset):
    - Matériel (CPU, disque, routeurs, …).
    - Logiciel (applications, bases de données, ...).
    - Données (configuration, archives, …).
    - Personnes (développeurs, administrateurs, …).
  - Quels sont les ressources vitales à l'entreprise ?
  - Difficulté d'évaluer proprement une ressource de type logiciel et donnée:
    - Un traitement erroné dans un logiciel de finance peut aller jusqu'à des poursuites légales.
    - Des données erronées dans un système embarqué peuvent causer l'endommagement de tout le système.

Politique de sécurité

- Ensemble de règles spécifiant:
  - Comment les ressources sont gérées afin de satisfaire les exigences de sécurité.
  - les actions permises et les actions interdites.
- Objectif:
  - Empêcher les violations de sécurité telles que: accès non autorisé, perte de données, interruption de services, etc.
- Etendu:
  - Organisationnel, ou individuel
- Implémentation
  - Partiellement automatisée, mais toutes les personnes sont impliquées.

Quelques exemples d'attaques

- Les menaces informatiques sont variées --> les entreprises sont de plus en plus victimes de piratage informatique.
- Selon les chiffres de l'ANSSI, les cyberattaques ont explosé en 2020, soit une hausse de 255% en un an.
- Les entreprises publiques et privées ont été largement ciblées par les organisations pirates, engendrant des violations de données en hausse de 20% en 2020.
- Dans le seul domaine hospitalier, ce sont pas moins de 20 millions de patients dont les documents numérisés personnels ont été divulgués et plus de 120 hôpitaux impactés.
- l'ANSSI a recensé 192 attaques par rançongiciels en 2020 contre 54 un an auparavant qui touchent plus particulièrement les petites structures PME.

Quelques exemples d'attaques

Les ransomwares, une menace informatique très répandue

- Également appelés rançongiciels (contraction de rançon et de logiciel)
- Il s'agit des virus les plus répandus actuellement.
- Les attaques se sont multipliées en 2020.
- Le principe de cette infection est le suivant : caché dans une pièce jointe, un programme malveillant chiffre les documents stockés dans l'ordinateur qui a été le premier infecté.
- Mais en quelques secondes, tous les fichiers partagés par les différents collaborateurs sont également bloqués.
- Impossible de les ouvrir, sauf si l'on paie une rançon (qui augmente au fil du temps pour faire monter la pression).
- Le prix à payer pour recouvrer ses données était de 11 000€ environ en 2019, cette somme atteint en moyenne 130 000€ en 2020
- De plus, le retour à la normale après une attaque peut prendre plusieurs jours ou semaines.

Quelques exemples d'attaques

Le phishing, une menace informatique sournoise

- Un autre danger fait toujours parler de lui : le phishing ou l'hameçonnage.
- Tout le monde connaît ces emails usurpant l'identité d'une entreprise privée ou d'une administration.
- On peut facilement tomber dans la piège : les cybercriminels utilisent des logos officiels.
- Ce sont alors des mots de passe qui sont récupérés ou l'installation de programme malveillant qui s'exécute avec le « consentement » de l'utilisateur.

- À ce jour, il s'agit de la technique la plus « rentable », selon la dernière étude de Google à ce sujet.
- Les chercheurs évaluent le taux de réussite de ce type d'attaque entre 12 et 25% !

Quelques exemples d'attaques

Les attaques DDos, une menace informatique paralysante

- Selon la société Netscout, le nombre d'attaques DDos (Distributed Denial of Service attack) a été porté à 5,4 millions au premier semestre 2021, en augmentation de 11% sur la même période en 2020.
- Ces attaques DDoS peuvent paralyser une entreprise dont l'activité principale repose sur Internet, typiquement un site de e-commerce.
- L'attaque DDos va consister à demander de se connecter ou d'envoyer des données en même temps vers une cible.
- Croulant sous les demandes de connexion ou inondée par des Gigabit/s de données, cette cible devient en quelques secondes inaccessible pour tous les internautes.
- Les pirates n'ont plus qu'à demander une rançon à l'éditeur du site pour arrêter leur attaque.

Quelques exemples d'attaques

La fuite de données, une menace informatique externe comme interne

- Elle peut être due à l'infiltration du réseau informatique par un pirate.
- Mais elle peut aussi provenir d'un salarié de l'entreprise !
- Ils ont des connaissances, des autorisations et le temps en leur faveur.
- La fuite de données peut être intentionnelle.: Un employé enregistre des informations critiques sur une clé USB, ou les envoie sur sa messagerie personnelle, pour ensuite les revendre à la concurrence.
- Cette fuite de données peut être également due à la négligence des collaborateurs qui naviguent sur des sites non sécurisés ou laissent leur session ouverte ou utilisent des password trop faibles.